# XXE — Exploiting XXE to Retrieve Files

**Plataforma:** PortSwigger Web Security Academy
**Categoría:** XML External Entity (XXE)
**Endpoint afectado:** `POST /product/stock`
**Archivo objetivo:** `/etc/passwd`

## 1. Descripción

Se identificó una vulnerabilidad de XML External Entity (XXE) en el endpoint `POST /product/stock`. La aplicación procesa datos XML sin impedir adecuadamente la declaración y resolución de entidades externas.

Mediante la modificación del documento XML enviado al servidor, se definió una entidad externa que apunta al archivo local `file:///etc/passwd`. Al referenciarla en el campo `productId`, el servidor devolvió contenido del archivo en la respuesta HTTP.

## 2. Evidencia

Se realizaron las siguientes capturas para documentar la explotación:

- **Evidencia 1:** Página inicial del laboratorio.



Description:

Ever feel like having a stag do in your own garden? Look no further than AbZroba Ball!

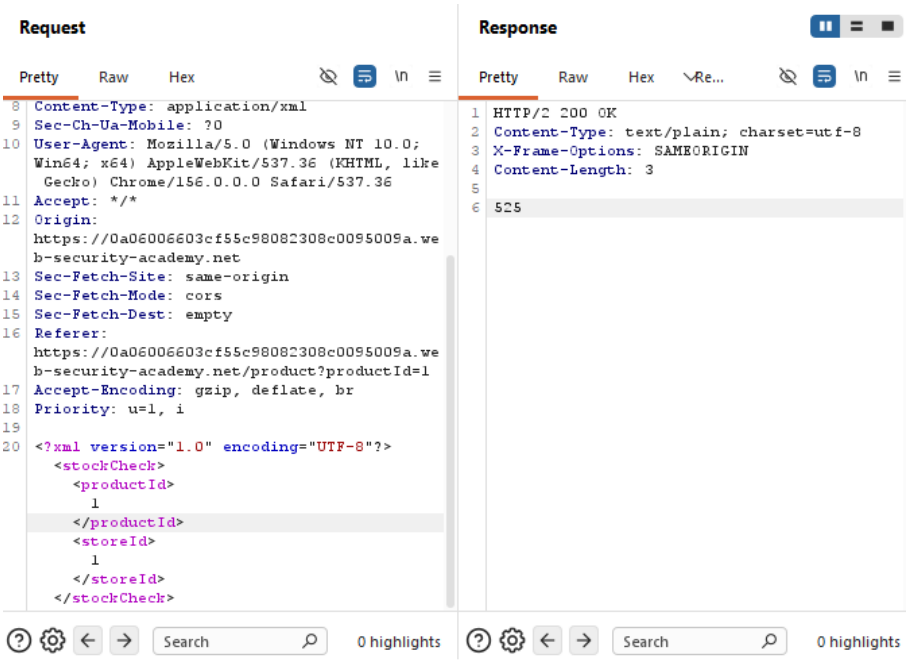
In a world where we are all trying to improve existing sports, surely one of the greatest achievements to date was someone getting kitted up for soccer and thinking, you know what would enhance this experience? Putting a huge inflatable ball around myself and others. With this, Zorbing was born. But luckily it is no longer confided to the day activity of a stag party, you can take home a collection of huge inflatables and smash into your friends while you also try and play a sport you weren't quite comfortable with beforehand.

Become a bouncing ball, knock your friends into next week and work out all at once thanks to this handy design. You'll have hours of fun and you're guaranteed a concussion free experience thanks to the durability of the AbZorba Balls!

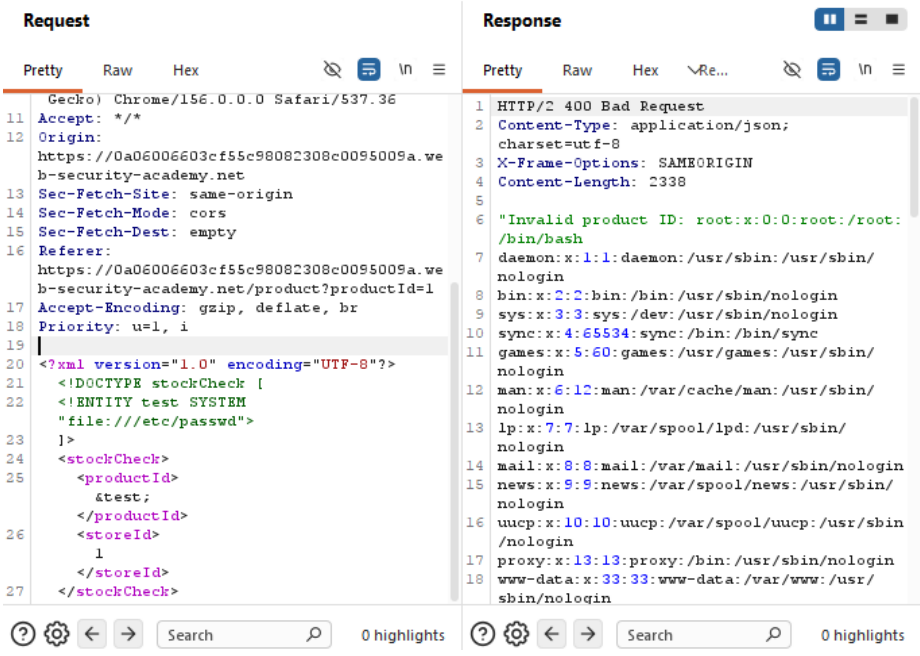
London Check stock

< Return to list

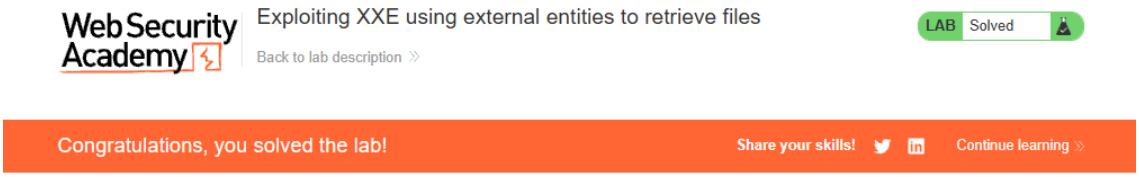
- **Evidencia 2:** Petición original `POST /product/stock`.




- **Evidencia 3:** Petición modificada con XXE y respuesta que revela contenido de `/etc/passwd`.




- **Evidencia 4:** Estado del laboratorio completado (*Solved*).



La respuesta HTTP presentó el estado `400 Bad Request`; sin embargo, el cuerpo de la respuesta reveló el contenido del archivo solicitado. Por lo tanto, el código de estado no impidió demostrar la lectura del archivo local.

# 3. Impacto (CIA)

- **Confidencialidad: Alta.** Un atacante podría leer archivos locales accesibles para el proceso de la aplicación, potencialmente exponiendo información sensible.
- **Integridad: No demostrada.** Durante esta prueba no se modificaron archivos ni datos.
- **Disponibilidad: No demostrada.** No se comprobó una interrupción del servicio.

El impacto real depende de los permisos del proceso, la configuración del parser XML y los archivos accesibles.

# 4. Causa raíz

El parser XML permite procesar declaraciones de entidades externas sin una configuración segura que impida la resolución de recursos locales. Esto permite que datos XML controlados por el usuario provoquen la lectura de archivos del sistema.

# 5. Remediación

- Deshabilitar la resolución de entidades externas en el parser XML.
- Deshabilitar las declaraciones DTD cuando no sean necesarias.
- Configurar la biblioteca XML con opciones seguras y protección específica contra XXE.
- Validar la estructura de los documentos XML como defensa adicional.
- Ejecutar la aplicación con privilegios mínimos.
- Incorporar pruebas de seguridad para verificar que las entidades externas no puedan acceder a recursos locales.

# 6. CVSS aproximado

**Estimación provisional: 6.5 — Medium (CVSS v3.1).**

Vector orientativo: `AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`

Esta estimación presupone que el endpoint requiere autenticación. Si puede explotarse sin autenticación, la puntuación debe recalcularse. La severidad definitiva depende de las condiciones reales de acceso y del impacto demostrado.

# 7. Prioridad

**Alta.** Corregir la configuración del parser XML y comprobar que las entidades externas no puedan leer archivos locales. La prioridad final debe ajustarse según la exposición del endpoint, los requisitos de autenticación y la sensibilidad de los archivos accesibles.

# Referencia

PortSwigger Web Security Academy — Exploiting XXE to retrieve files